

PROJET DROIT

Le RGPD est un ensemble de lois ayant pour but de protéger les données à caractère personnel : des données permettant d'identifier directement, ou indirectement un individu.

Étant donné que vous traitez ce type de données il est nécessaire de nommer un Délégué à la Protection des Données (DPO) qui sera désigné directement sur le site de la CNIL via un formulaire en ligne. La personne qui remplira cette fonction peut faire partie de l'entreprise ou être une personne extérieure, mais il/elle devra dans tous les cas avoir une certaine expertise en matière de législation et pratiques en matière de protection des données, une bonne connaissance du secteur d'activité de votre entreprise, etc.

Le DPO devra aussi être amené à tenir un registre de traitement, qui devra être conçu comme un outil de pilotage et de démonstration de la conformité au RGPD et qui devra être mis à jour régulièrement. Votre entreprise ayant moins de 250 salariés, les traitements de données qui devront être enregistrés sont plus limités, mais cela ne réduit en aucun cas leur importance. Voici une liste des traitements qu'il vous est nécessaire d'enregistrer :

- Traitements non occasionnels tels que la gestion de la paie ou la gestion des clients/prospects et fournisseurs
- Traitements susceptibles de comporter un risque pour les droits et libertés des personnes
- Traitements qui portent sur des données sensibles (exemple : données de santé, infractions, etc.).

Afin d'être en conformité au vu du RGPD, nous vous préconisons de commencer par trier les données en ne conservant uniquement les données nécessaires à l'activité de votre entreprise, déterminer leur durée de conservation, assurer la sécurité et la confidentialité de ces données ainsi que de vous assurer que ces données ont été récoltées avec le consentement des personnes concernées.

I) Tri des données – que conserver (ou non)?

1) Données à ne PAS conserver

- Données dites « sensibles » : données à caractère personnel qui font apparaître, directement ou indirectement, les origines raciales ou ethniques, les opinions politiques, philosophiques ou religieuses ou l'appartenance syndicale des personnes, des données génétiques, des données biométriques ou des données relatives à leur santé ou à leur vie sexuelle ou encore aux infractions et condamnations qu'elles ont encourues.

Il est important de faire la distinction car il est interdit de conserver ces données sans le consentement éclairé de la personne concernée, parmi lesquelles on trouve dans celles que vous collectez actuellement :

- La référence de passeport
- L'appartenance syndicale
- Le nombre de jours de grève suivis
- Les pathologies des salariés
- Données non-pertinentes/non-essentiels au fonctionnement de l'entreprise ou non-indispensables au traitement :
 - La nature des études suivies par les enfants
 - La profession des parents de l'employé

Toutes ces données ne doivent pas être conservées par l'entreprise.

2) Données pertinentes

Le reste des données, que cela soit celles par rapport à l'identification de l'employé ou le suivi de sa carrière et de sa formation peuvent tout à fait être conservées de manière licite et conforme au RGPD. Il vous faudra cependant être capable de justifier la raison de la conservation de ces données et l'utilisation que vous en faites.

Par exemple, les données concernant l'identification de l'employé tel que le nom, prénom, ou encore une photo vous sont nécessaires afin de créer la fiche d'un employé et leur conservation/utilisation est donc justifiée.

II) Déterminer la durée de conservation

Afin de définir les durées de conservations des données nous préconisons la création de catégories. Nous vous suggérons les trois catégories suivantes : les candidats (qui n'ont passé qu'un entretien), les employés et les anciens employés.

- Les candidats : nous pensons que 12 mois de conservation sont suffisants. Il faut nonobstant demander le consentement des candidats pour pouvoir garder ces données. Il y a aussi la possibilité d'étendre la durée de conservation en envoyant une demande par mail au candidat concerné.
- Les employés : la durée de conservation s'étend sur toute la durée du contrat de travail.
- Les anciens employés : nous préconisons de garder au minimum 2 ans les données en cas de litige avec l'employé.

III) Sécurité et confidentialité des données

Pour assurer la sécurité des données personnelles, nous vous préconisons de d'autoriser l'accès général aux données au service RH uniquement et de mettre en place une base de données sécurisée. Il est important que chaque salarié qui traite des données personnelles ait un mot de passe qui soit régulièrement changé afin que l'accès aux données soit le plus sécurisé possible. De plus, les droits d'accès aux données doivent être définis de manière claire et précise afin que chacun n'ait accès qu'aux données qu'il/elle a réellement besoin de consulter ou utiliser, rien de plus. Il serait aussi possible de paramétrer les ordinateurs afin qu'ils se verrouillent automatiquement après une courte période de veille/sans activité, ce qui limiterait de potentielles fuites.

IV) Sanctions possibles

A titre d'information, il existe différents types de sanctions en cas de non-respect du RGPD :

- Des sanctions pénales pouvant aller jusqu'à 5 ans d'emprisonnement et une amende de 300 000€ ou 1 500 000€.
- Des sanctions administratives pouvant aller jusqu'à 4% du chiffre d'affaires annuel mondial de l'exercice précédent.
- Des sanctions civiles lorsqu'une personne subit un préjudice lié à une fuite de données.
- Des sanctions disciplinaires, en cas de faute grave d'un employé.